

Sécurité informatique

Introduction

Irit - M2DL/SECIL

Pierre-Yves Bonnetain-Nesterenko
py.bonnetain@ba-consultants.fr

B&A Consultants – 243, route d'Albi – BAL 38 – 31200 Toulouse

Année 2025-2026

B&A Consultants

- Cabinet de conseil en sécurité informatique créé en 1996.
- Conseils, suivi et assistance en sécurité informatique.
- Audits de sécurité, de configurations, de code. . .
- Audits et accompagnement conformité RGPD.
- Tests d'intrusion, tests d'applications.
- Réponse à incidents, analyses *post-mortem*.
- Analyses de risques, gestion des risques sur l'information.
- Ingénierie de la sécurité informatique, recherche de solutions.
- Formations à la sécurité informatique.
- Expertise judiciaire (civile ou pénale) et expertises privées.
- Animateur de ReSIST, groupe de travail régional de l'OSSIR
(www.ossir.org/resist)

Préparation pour les travaux pratiques

- Nécessité de connaître/être capable d'utiliser les environnements suivants :
 - Linux/bash
 - SQL/MySQL
 - Javascript
- Sinon, les travaux pratiques seront plus difficiles à réaliser
- Pas nécessaire être expert sur ces sujets

Plan

- 1 Qui cherche les problèmes ?
 - Dans des systèmes et applications
 - Fonction « mot de passe perdu »
 - Code is law, but law can be wrong
- 2 Sans oublier le réseau

Remove my password from lists so hackers won't be able to hack me #155

Closed assafnativ wants to merge 1 commit into `danielmiessler:master` from `assafnativ:remove_my_password`

Conversation 379 Commits 1 Checks 0 Files changed 30



assafnativ commented on Dec 21, 2017

No description provided.

👍 1773 🗑️ 67 😬 1727 🏆 430 🤖 81 ❤️ 584

Remove my password from lists so hackers won't be able to hack me

3cb9418



mitcom reviewed on Dec 21, 2017

[View reviewed changes](#)

Passwords/10_million_password_list_top_1000.txt

```
... .. @ -344,7 +344,6 @@ blue
344 344 liverpool
345 345 theman
346 346 bandit
347 - dolphins
```

mitcom on Dec 21, 2017 • edited

Reviewers

jasonmp85

D3X

god

n4zim

Mixaill

masterrr

lucianoqueiroz

lost-guadelenn

SammysHP

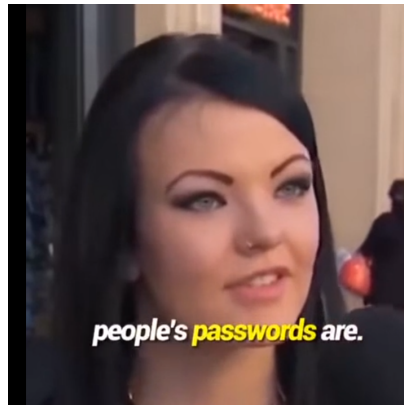
jakeatwork

elmar-chen

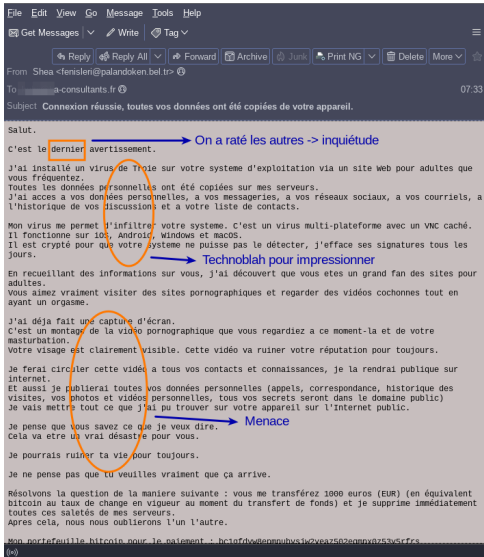
RossBille

mitcom



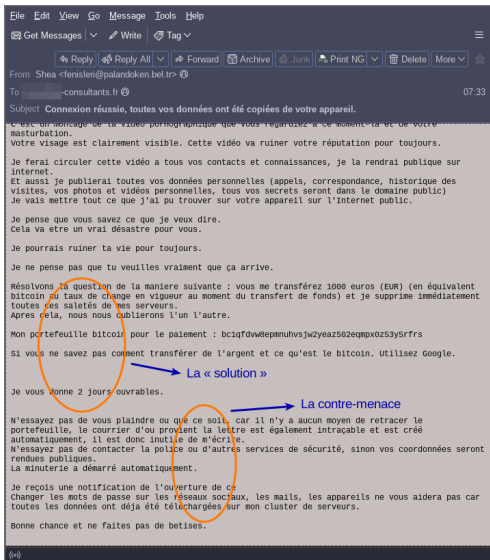


De l'humain, rien que de l'humain



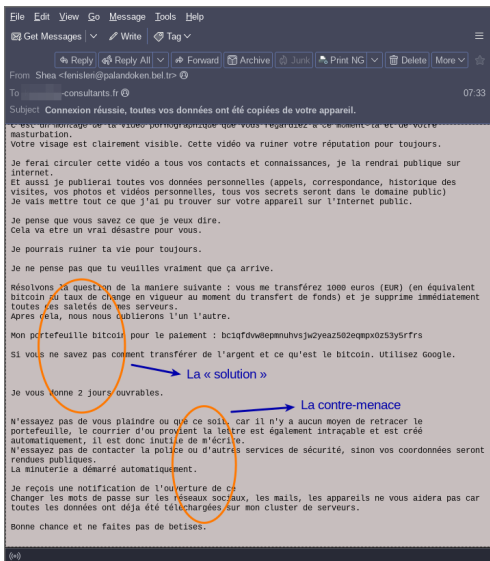
- Semi-particularisation du message pour que cible se sente concernée ;
- Technoblah pour victime
« je comprends pas tout mais mots-clés anxiogènes » ;
- Menace (sociale ici) ;

De l'humain, rien que de l'humain



- Semi-particularisation du message pour que cible se sente concernée ;
- Technoblah pour victime
« je comprends pas tout mais mots-clés anxiogènes » ;
- Menace (sociale ici) ;
- Et solution proposée.

De l'humain, rien que de l'humain



- Semi-particularisation du message pour que cible se sente concernée ;
- Technoblah pour victime
« je comprends pas tout mais mots-clés anxiogènes » ;
- Menace (sociale ici) ;
- Et solution proposée.

Variantes multiples

Existe avec « reçu contrat pour vous tuer », bombe, etc.

Une nouveauté (en 2023)

From GESTION LOCATIVE <gestion.loyers.com@gmail.com> 📧

To undisclosed-recipients;;

Subject **REF2 : RAPPEL / INFORMATION**

Cher(e) locataire,

Sauf erreur ou omission, nous attendons toujours le paiement de votre loyer conformément au contrat de bail.

Nous vous remercions de bien vouloir régulariser votre situation dès réception de notre présent message.

Nous tenons également à vous informer que nos coordonnées bancaires ont été modifiées depuis le 27 Février 2023.

Ci-dessous les nouvelles références

Titulaire du compte : BENOIT RUBAN

IBAN : FR7621833000010001515495651

BIC : PRNSFRP1

Bien à vous.

Pour le département de la comptabilité

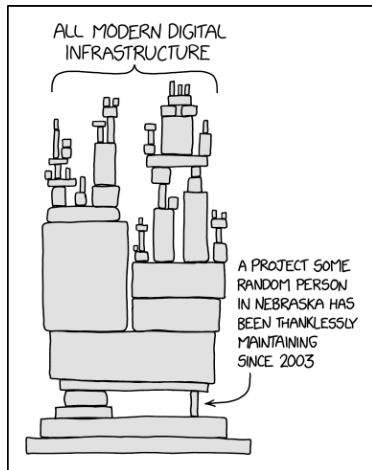
Le Service Gestion Locative

Notez que le
numéro de
compte est celui
d'une *mule*, pas
celui des
donneurs
d'ordre.

Plan

- 1 Qui cherche les problèmes ?
 - Dans des systèmes et applications
 - Fonction « mot de passe perdu »
 - Code is law, but law can be wrong

D'une façon générale...



(c) XKCD - Randall Munroe

- **Très difficile** savoir
« quoi » compose ensemble
technique (BoS ? chaîne
d'approvisionnement ?) ;
- donc... surprises inévitables ;
- architectures, environnements,
logiciels, individus doivent être
« aussi prêts » que possible pour
bien réagir ;
- bon courage...

Pendant qu'on en parle...



18 Popular Code Packages Hacked, Rigged to Steal Crypto

September 8, 2025

2 Comments

At least 18 popular JavaScript code packages that are collectively downloaded more than two billion times each week were briefly compromised with malicious software today, after a developer involved in maintaining the projects was phished. The attack appears to have been quickly contained and was narrowly focused on stealing cryptocurrency. But experts warn that a similar attack with a slightly more nefarious payload could lead to a disruptive malware outbreak that is far more difficult to detect and restrain.

Brian Krebs – Krebs On Security

Which?

**URGENT
RECALL**

Paw Patrol snacks from Lidl



All Butter Mini Biscotti Biscuits x 5, Choc Chip Mini Biscotti Biscuits x 5, Yummy Bake Bars Raspberry Flavour x 5, Yummy Bake Bars Apple Flavour x 5

Website URL published on packaging has been compromised and contains explicit content unsuitable for children.

Refrain from viewing the website and return product to the nearest Lidl store for a full refund.

Qui aurait cru que la compromission d'un site amènerait au rappel de paquets de biscuits pour enfants ???

Plan

- 1 Qui cherche les problèmes ?
 - Dans des systèmes et applications
 - Fonction « mot de passe perdu »
 - Code is law, but law can be wrong

Une application spécifique

Source [Troy Hunt](#), 3 octobre 2020

- Grindr
- Site de rencontres
- Données personnelles extrêmement sensibles : contacts, messages, photos...
- Donc impérieuse nécessité d'une sécurité élevée



Mot de passe perdu

- Page sur le site web ;
- Indication de l'adresse électronique du compte ;

Use Grindr on your computer quickly and discreetly

It looks like a typical email interface so your business stays private, no matter who's looking over your shoulder.

Login with Grindr Account



How To Log In To Grindr Web

- On your phone, open Grindr
- Go to your Profile Drawer and select Grindr Web
- Scan the code with your phone
- Confirm your login with the in-app pop up dialog

OR

Find Your Account

Enter your Grindr email linked to your account.

Next steps

Back to login

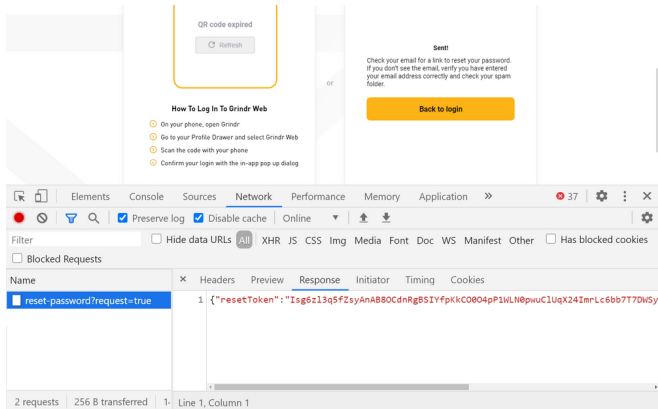
How is this safe for work? ⓘ
Any issue feedback?
Any feature request?

Please upgrade your Grindr app to the latest version and turn on its push notification

This site is protected by reCAPTCHA and the Google Privacy Policy and Terms of Service apply

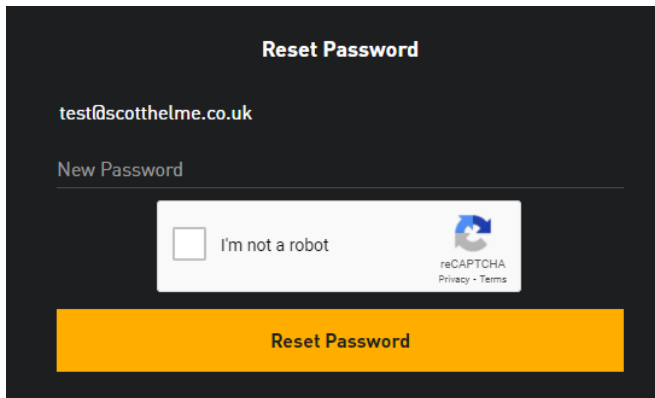
Dans les données renvoyées

- Jeton d'authentification ;
- Pas visible directement ;
- Visible avec outils de développement ;



Connexion sur le site

- URL **connue** de réinitialisation du mot de passe
- Et c'est fini.



The screenshot shows a 'Reset Password' form on a dark background. At the top, the title 'Reset Password' is displayed in white. Below it, the email address 'test@scotthelme.co.uk' is entered in a white text field. Underneath, the label 'New Password' is followed by an empty white input field. A reCAPTCHA challenge is presented in a white box, featuring a checkbox, the text 'I'm not a robot', and the reCAPTCHA logo with links for 'Privacy' and 'Terms'. At the bottom of the form, there is a large orange button with the text 'Reset Password' in black.

Connexion sur le site

- URL **connue** de réinitialisation du mot de passe
- Et c'est fini.

Reset Password

Your password has been changed.

New Password

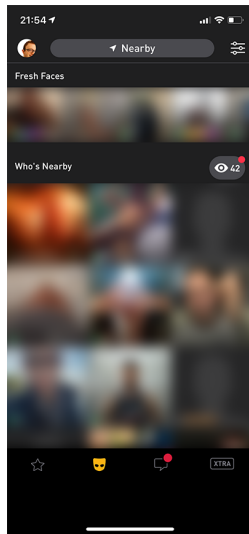
☐ I'm not a robot


reCAPTCHA
[Privacy](#) • [Terms](#)

Reset Password

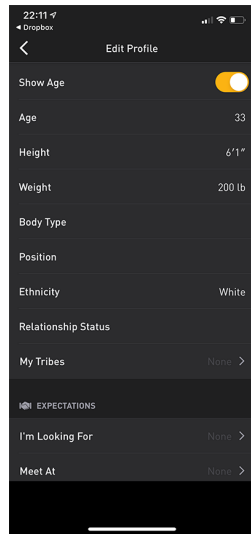
Et ensuite ?

- Contrôle total du compte ;



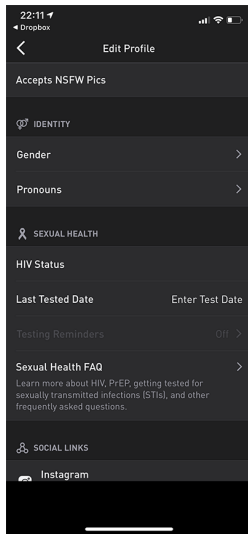
Et ensuite ?

- Contrôle total du compte ;
- Avec tout ce qui vient avec ;



Et ensuite ?

- Contrôle total du compte ;
- Avec tout ce qui vient avec ;
- Par rapport à la fonction du système (site de rencontres)



Conclusion

- « Petite » erreur dans la conception du système ;
- Exploitation triviale ;
- N'oubliez pas
 - Fonction « mot de passe perdu » peut être invoquée par n'importe qui ;
 - Pas uniquement par propriétaire légitime ;
 - Donc aucun secret ne doit être affiché ;
 - Pas même « compte inconnu » (absence du message confirme que le compte existe).

Plan

- 1 Qui cherche les problèmes ?
 - Dans des systèmes et applications
 - Fonction « mot de passe perdu »
 - Code is law, but law can be wrong

Plan

- Dans des systèmes et applications
- Fonction « mot de passe perdu »
- Code is law, but law can be wrong
 - Erreur de base du développeur
 - Erreur de base ou compromission géniale ?

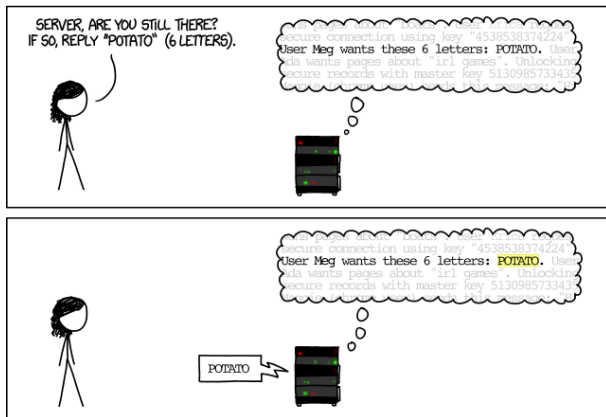
Heartbleed - printemps 2014

- C'est quoi exactement Heartbleed ?
- Mortel, critique, grave, pas grave ?



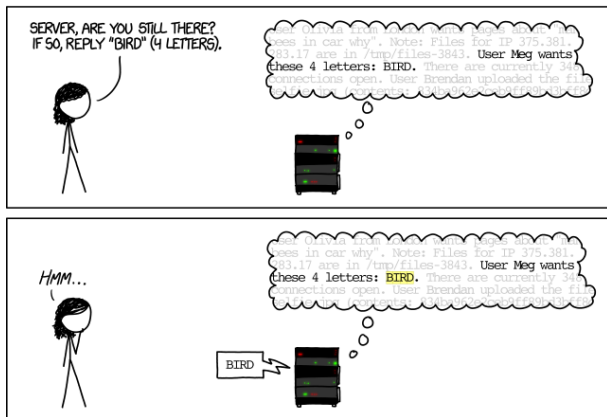
Heartbleed - printemps 2014

(c) XKCD – Randall Munroe



Heartbleed - printemps 2014

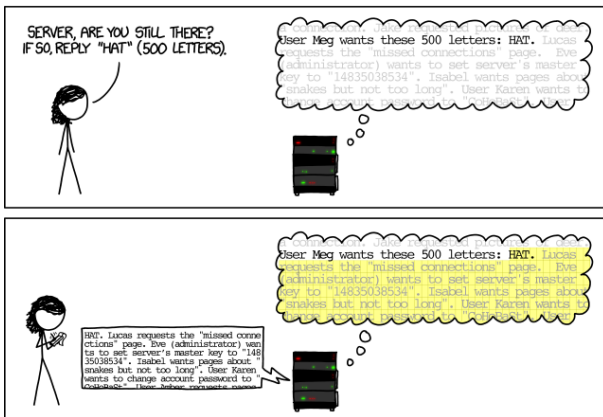
(c) XKCD – Randall Munroe



Utilisation « créative » sous-fonction heartbeat de TLS.

Heartbleed - printemps 2014

(c) XKCD – Randall Munroe



Extraction d'informations de la mémoire du serveur.

Conséquences ?

- Compromission (potentielle) des informations ayant transité dans la mémoire du serveur.
- Aucune trace, aucun élément journalisé pour confirmer ou infirmer compromission.
- Dans le doute. . . considérer la compromission comme avérée.

Actions nécessaires (après mise à jour OpenSSL)

Révoquer/changer toute information sensible ayant transité par le serveur : clés de chiffrement, mots de passe. . . Anticiper conséquences divulgation échanges chiffrés.

Oui mais. . .

Beaucoup (trop !) d'équipements (imprimantes, bornes Wifi, caméras, objets connectés. . .) n'ont pas de capacité de mise à jour.

Comment est-ce possible ?

- Utilisation d'une information (ici, longueur de la chaîne reçue) fournie par l'extérieur
- Sans vérifier la validité de cette information

Ca marche souvent, mais (bugs, malveillance) c'est une mauvaise idée.

Conclusion

- **Toujours** valider une information provenant de l'extérieur du système. L'extérieur, c'est tout sauf la RAM du processus en cours d'exécution (disque, base de données, réseau, etc.).
- Mettre une pression d'enfer sur vos fournisseurs et acheteurs pour s'assurer de la maintenabilité des équipements achetés.

Plan

- Dans des systèmes et applications
- Fonction « mot de passe perdu »
- Code is law, but law can be wrong
 - Erreur de base du développeur
 - Erreur de base ou compromission géniale ?

Ca c'est du code...

Février 2014 – extrait du code de SecureTransport (TLS). Utilisé par OS X et iOS pour valider les certificats X509 reçus...

```
1 SSLVerifySignedServerKeyExchange(SSLContext *ctx, bool isRsa, SSLBuffer signedParams,  
2                               uint8_t *signature, UInt16 signatureLen)  
3 {  
4     OSStatus      err;  
5  
6     ...  
7  
8     if ((err = SSLHashSHA1.update(&hashCtx, &serverRandom)) != 0)  
9         goto fail;  
10    if ((err = SSLHashSHA1.update(&hashCtx, &signedParams)) != 0)  
11        goto fail;  
12    if ((err = SSLHashSHA1.final(&hashCtx, &hashOut)) != 0)  
13        goto fail;  
14  
15    ...  
16  
17    fail:  
18        SSLFreeBuffer(&signedHashes);  
19        SSLFreeBuffer(&hashCtx);  
20        return err;  
21  
22  
23 }
```

Question

Comportement de la fonction ?



Oui mais ensuite ?

- Second goto (ligne 12) met un terme aux contrôles du certificat reçu
- err vaut zéro (fonction ligne 10 renvoie 0).
- return err; (ligne 21) renvoie zéro = succès.
- Conséquence ?
 - Certificat n'est pas complètement validé par l'application
 - Faux certificat signé par une AC quelconque
 - Ou un certificat sans signature
 - ⇒ attaque par intermédiation (MITM) triviale
- En bref : TLS n'offre plus aucune protection.

Un peu de perspective...

Tout ça avec une seule ligne de code, 11 caractères en comptant les espaces.

Comment est-ce possible ?

- Copier-coller de trop ou malfeasance/porte dérobée ?
- Collision sémantique « goto fail = erreur » alors que ce n'est pas le cas
- Les compilateurs peuvent aider
- Relecture de code n'est pas un luxe. C'est difficile, long et cher.

Conclusions

- Plus le code est sensible, plus la relecture doit être soignée, par des personnes compétentes **n'ayant pas écrit le code**.
- Assurez-vous que vos outils peuvent être mis à jour, y compris les bibliothèques et dépendances.
- Attention aux compilations statiques (typique embarqué).

Plan

- 1 Qui cherche les problèmes ?
- 2 Sans oublier le réseau
 - DNS menteurs
 - Interception de flux

Question innocente...

Quel protocole

- ... est indispensable au fonctionnement d'un réseau
- ... est utilisé par toutes les applications, tous les systèmes
- ... « casse toute Internet » lorsqu'il ne fonctionne plus ou mal ?

Question innocente...

Quel protocole

- ... est indispensable au fonctionnement d'un réseau
- ... est utilisé par toutes les applications, tous les systèmes
- ... « casse toute Internet » lorsqu'il ne fonctionne plus ou mal ?

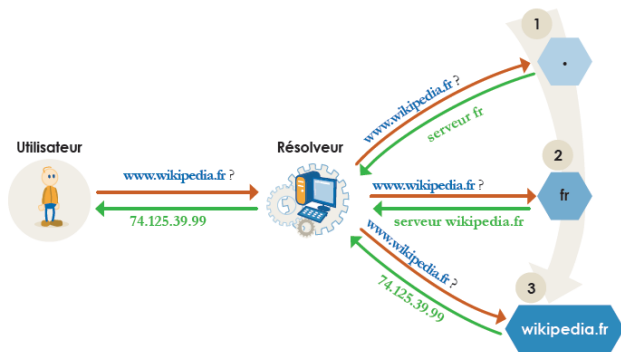
Réponse

Le DNS, qui est à Internet ce que l'oxygène est aux organismes vivants.

Comment fonctionne le DNS ?

... j'attends...

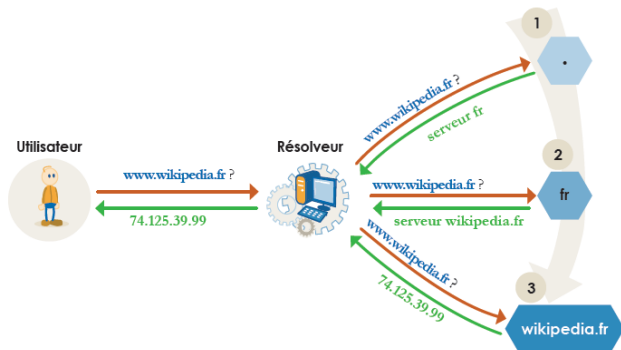
Comment fonctionne le DNS ?



Trois groupes de composants

- le client ;
- le(s) (ré)solveur(s) ;
- les serveurs.

Comment fonctionne le DNS ?



Trois groupes de composants

- le client ;
- le(s) (ré)solveur(s) ;
- les serveurs.

Question

Quels risques voyez-vous, et où ?

Plan

- 2 Sans oublier le réseau
 - DNS menteurs
 - Interception de flux

Solveur menteur (ou DNS menteur)

- Solveur point de passage obligé pour une résolution (y compris solveur local machine) ;
- contrôle du solveur signifie contrôle **toutes** résolutions qui lui sont demandées ;
- renvoie « ce qu'il veut » (réponse véridique ou non) ;
- **méthode légale** pour blocage de sites (solveurs des principaux FAI sont solveurs menteurs) ;
- idem en entreprise (filtrage navigation) ;
- mais... si un solveur de votre chaîne de résolution est sous contrôle (malveillant) ?

Solveur sous contrôle

- Contrôle toutes les résolutions demandées (Brésil 2018, routeurs DLink) ;
- envoie les utilisateurices « là où il veut » (90% vers bons systèmes, 10% ... ailleurs) ;
- difficile à détecter si systèmes d'arrivée bien faits (même charte graphique, etc.) ; TLS aide beaucoup, mais utilisateurs pas toujours vigilants ;
- très difficile à détecter si services « non interactifs » (courrier électronique, transfert de fichiers, etc.) ;
- DNSSEC (signature cryptographique des réponses, avec chaînage depuis racine) permet détection.

Plan

- 2 Sans oublier le réseau
 - DNS menteurs
 - Interception de flux

Il est beau mon réseau local...

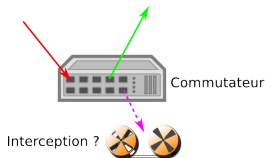
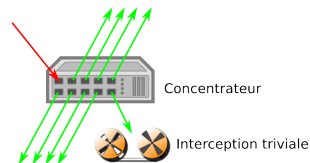
Un cas d'école...

- Réseau simple (bâtiment, étage, plateau...)
- Construit en étoile autour de commutateurs réseau

Comment intercepter les paquets qui circulent sur le réseau ?



Concentrateurs et commutateurs



- Principales différences entre les commutateurs (switch) et les concentrateurs (hubs)
 - Concentrateur (pratiquement disparus aujourd'hui) diffuse sur tous ses ports
 - Commutateur envoie sur le port où le destinataire est joignable
- Concentrateur : interception triviale, par nature.
- Commutateur : interception facile si on sait comment fonctionne un commutateur.

Interception locale

Trois grandes possibilités :

Configuration commutateur Accès au commutateur, mot de passe standard ou trivial, activation port mirroring.

Fonctionnement commutateur Attaque du commutateur par dépassement de ses capacités. Problème : maintenir la saturation.

- Visible pour les exploitants (saturation)
- Imparfait (certains paquets ne seront pas vus quand même)

Protocole sous-jacent Attaque d'un protocole lié à Ethernet (niveau 2)

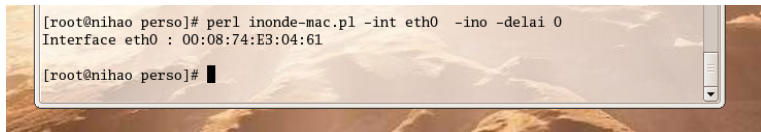
Une conséquence

Même sur le réseau local, pas d'échanges en clair.

Un commutateur qui va paniquer

Saturation de la table *Adresse MAC* ↔ *Port* par envoi de paquets ARP « gratuits ».

- Commutateur : composant de télécommunications, **pas** de sécurité.
- Incident ⇒ mission d'abord ⇒ transmettre les paquets ⇒ sur tous les ports.
- Quelques lignes de Python suffisent (merci Scapy !)

A terminal window with a light blue background and a dark blue border. The text inside the terminal is as follows:

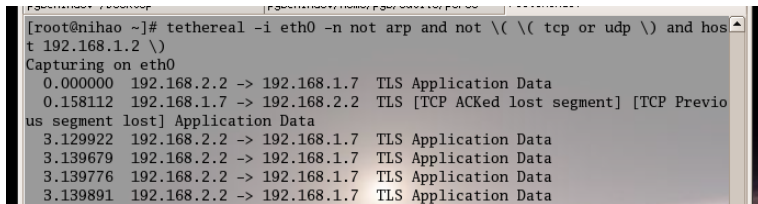
```
[root@nihao perso]# perl inonde-mac.pl -int eth0 -ino -delai 0
Interface eth0 : 00:08:74:E3:04:61

[root@nihao perso]# █
```

Un commutateur qui va paniquer

Saturation de la table *Adresse MAC* ↔ *Port* par envoi de paquets ARP « gratuits ».

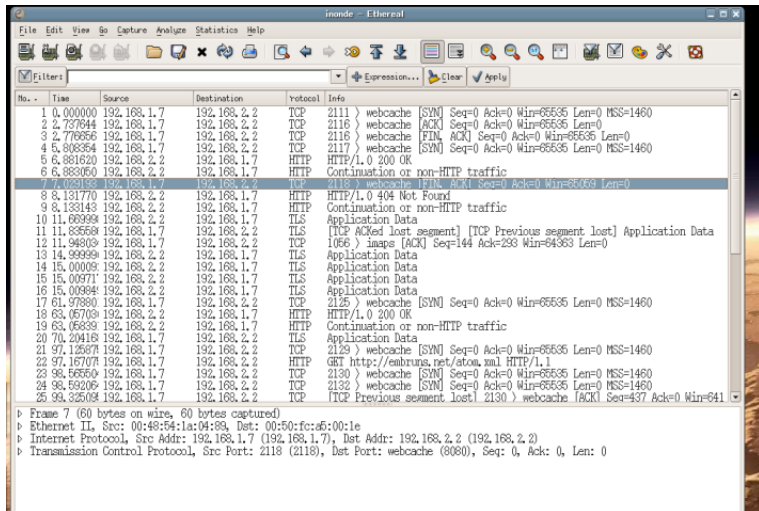
- Commutateur : composant de télécommunications, **pas** de sécurité.
- Incident ⇒ mission d'abord ⇒ transmettre les paquets ⇒ sur tous les ports.
- Quelques lignes de Python suffisent (merci Scapy !)



```
[root@nihao ~]# tethereal -i eth0 -n not arp and not \( \( tcp or udp \) and host 192.168.1.2 \)
Capturing on eth0
0.000000 192.168.2.2 -> 192.168.1.7 TLS Application Data
0.158112 192.168.1.7 -> 192.168.2.2 TLS [TCP ACKed lost segment] [TCP Previous segment lost] Application Data
3.129922 192.168.2.2 -> 192.168.1.7 TLS Application Data
3.139679 192.168.2.2 -> 192.168.1.7 TLS Application Data
3.139776 192.168.2.2 -> 192.168.1.7 TLS Application Data
3.139891 192.168.2.2 -> 192.168.1.7 TLS Application Data
```

Un commutateur qui panique

Manque parfois des morceaux (ici, entre paquets 16 et 17) :

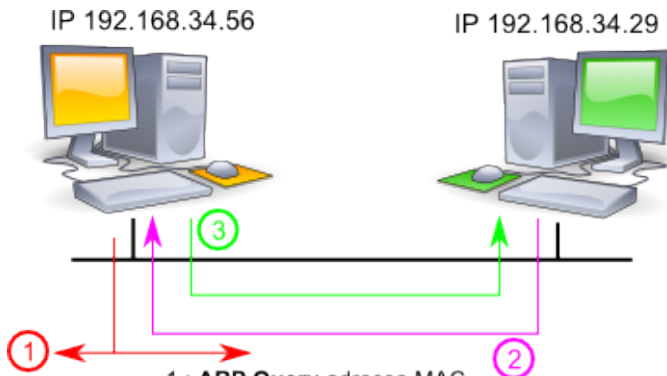


The image shows a Wireshark packet capture window titled "inonde - Ethereal". The packet list pane shows a series of packets from 1 to 25. Packet 16 is a TLS Application Data packet (Seq=0, Win=65535, Len=0). Packet 17 is a TLS Application Data packet (Seq=144, Ack=233, Win=64363, Len=0). The packet details pane shows the selected packet (Frame 7) as a TLS Application Data packet (Seq=0, Win=65535, Len=0). The packet bytes pane shows the raw data of the selected packet, which is a TLS Application Data packet (Seq=0, Win=65535, Len=0).

No.	Time	Source	Destination	Protocol	Info
1	0.000000	192.168.1.7	192.168.2.2	TCP	2111 > webcache [SYN] Seq=0 Ack=0 Win=65535 Len=0 MSS=1460
2	2.737644	192.168.1.7	192.168.2.2	TCP	2116 > webcache [ACK] Seq=0 Ack=0 Win=65535 Len=0
3	2.776656	192.168.1.7	192.168.2.2	TCP	2116 > webcache [FIN, ACK] Seq=0 Ack=0 Win=65535 Len=0
4	5.808354	192.168.1.7	192.168.2.2	TCP	2117 > webcache [SYN] Seq=0 Ack=0 Win=65535 Len=0 MSS=1460
5	6.881620	192.168.2.2	192.168.1.7	HTTP	HTTP/1.0 200 OK
6	6.883050	192.168.2.2	192.168.1.7	HTTP	Continuation or non-HTTP traffic
7	7.029193	192.168.1.7	192.168.2.2	TCP	2118 > webcache [FIN, ACK] Seq=0 Ack=0 Win=65535 Len=0
8	8.131770	192.168.2.2	192.168.1.7	HTTP	HTTP/1.0 404 Not Found
9	8.133143	192.168.2.2	192.168.1.7	HTTP	Continuation or non-HTTP traffic
10	11.669999	192.168.2.2	192.168.1.7	TLS	Application Data
11	11.835568	192.168.1.7	192.168.2.2	TLS	[TCP ACKed lost segment] [TCP Previous segment lost] Application Data
12	11.948039	192.168.1.7	192.168.2.2	TCP	1056 > inaps [ACK] Seq=144 Ack=233 Win=64363 Len=0
13	14.999999	192.168.2.2	192.168.1.7	TLS	Application Data
14	15.000009	192.168.2.2	192.168.1.7	TLS	Application Data
15	15.009711	192.168.2.2	192.168.1.7	TLS	Application Data
16	15.009844	192.168.2.2	192.168.1.7	TLS	Application Data
17	61.978880	192.168.1.7	192.168.2.2	TCP	2125 > webcache [SYN] Seq=0 Ack=0 Win=65535 Len=0 MSS=1460
18	63.057039	192.168.2.2	192.168.1.7	HTTP	HTTP/1.0 200 OK
19	63.058339	192.168.2.2	192.168.1.7	HTTP	Continuation or non-HTTP traffic
20	70.204168	192.168.1.7	192.168.2.2	TLS	Application Data
21	97.125878	192.168.1.7	192.168.2.2	TCP	2129 > webcache [SYN] Seq=0 Ack=0 Win=65535 Len=0 MSS=1460
22	97.167078	192.168.1.7	192.168.2.2	HTTP	GET http://embruns.net/atom.xml HTTP/1.1
23	98.565500	192.168.1.7	192.168.2.2	TCP	2130 > webcache [SYN] Seq=0 Ack=0 Win=65535 Len=0 MSS=1460
24	98.592060	192.168.1.7	192.168.2.2	TCP	2132 > webcache [SYN] Seq=0 Ack=0 Win=65535 Len=0 MSS=1460
25	99.325034	192.168.1.7	192.168.2.2	TCP	[TCP Previous segment lost] 2130 > webcache [ACK] Seq=437 Ack=0 Win=641

Frame 7 (60 bytes on wire, 60 bytes captured)
Ethernet II, Src: 00:48:54:1a:04:89, Dst: 00:50:fc:a5:00:1e
Internet Protocol, Src Addr: 192.168.1.7 (192.168.1.7), Dst Addr: 192.168.2.2 (192.168.2.2)
Transmission Control Protocol, Src Port: 2118 (2118), Dst Port: webcache (8080), Seq: 0, Ack: 0, Len: 0

Fonctionnement ARP



1 : **ARP Query** adresse MAC
associée à IP 192.168.34.29 ?

2 : **ARP Answer** IP portée par
MAC AA:BB:CC:DD:EE:FF

3 : communication

Mascarade ARP

- Echanges sur un segment Ethernet n'utilisent pas adresse IP mais adresse MAC (physique) du destinataire.
- ARP (Adress Resolution Protocol) pour initialiser l'échange :
« quelle adresse MAC porte l'adresse IP a.b.c.d ? »
- Pas d'authentification des paquets ARP
- Mascarade (ou empoisonnement) : signaler qu'une certaine adresse IP est « maintenant » portée par notre adresse MAC.

Résultat

Détournement/interception d'un échange local (y compris s'il est déjà en cours)

Pas toujours malveillant

Fonctionnement des boîtiers redondants (type HSRP).

Mascarade ARP

- Echanges sur un segment Ethernet n'utilisent pas adresse IP mais adresse MAC (physique) du destinataire.
- ARP (Adress Resolution Protocol) pour initialiser l'échange :
« quelle adresse MAC porte l'adresse IP a.b.c.d ? »
- Pas d'authentification des paquets ARP
- Mascarade (ou empoisonnement) : signaler qu'une certaine adresse IP est « maintenant » portée par notre adresse MAC.

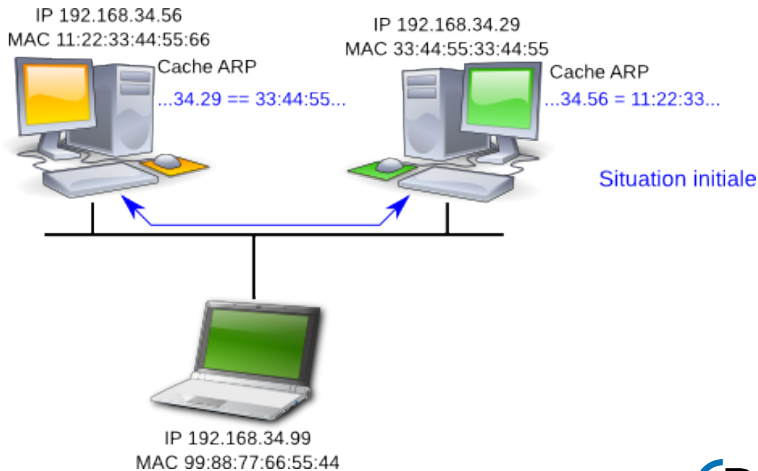
Résultat

Détournement/interception d'un échange local (y compris s'il est déjà en cours)

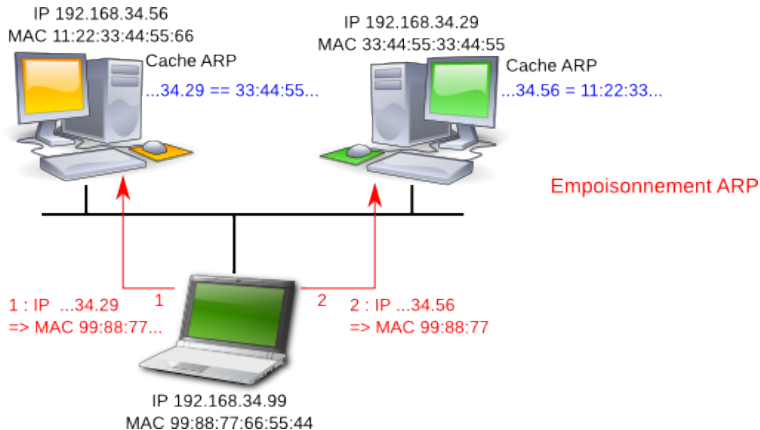
Conclusion

Chiffrement des flux. Tout le temps. En interne comme en externe.

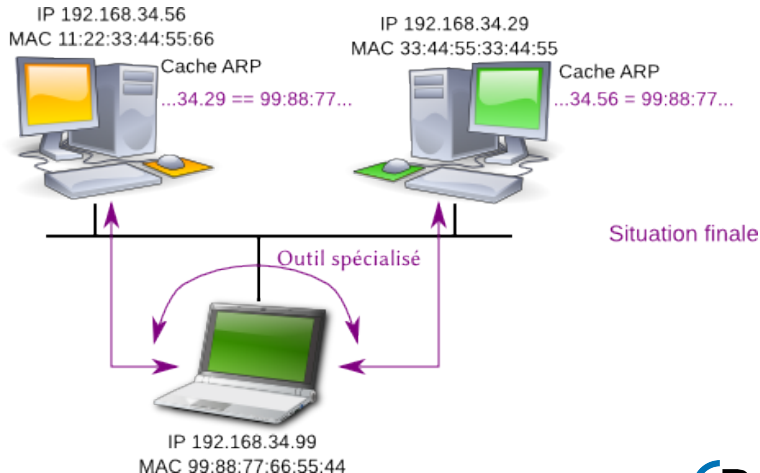
Empoisonnement ARP



Empoisonnement ARP



Empoisonnement ARP



Ça signifie quoi ?

- Vous ne savez pas qui écoute vos communications ;
- Y compris sur un réseau local, sur un mini-réseau local domiciliaire, sur la radio (wifi, bluetooth...) ;
- Donc **chiffrez tous vos échanges** ;
- Si vous avez des « services internes » (web, serveur de boîtes à lettres, BDD...), même inaccessibles depuis l'extérieur, **chiffrez les échanges** avec ces systèmes ;
- Si vous avez des services ne supportant pas nativement TLS (ou autre mode de chiffrement)
 - changez d'outil (pas toujours facile) ;
 - ou mettez en place une surcouche de chiffrement (stunnel et autres).
- Mais pas toujours possible (capacité calcul/énergie points concernés)

Dans la même veine...

- Pouvez-vous trouver d'autres protocoles permettant des « fantaisies » similaires ?
- ... protocoles internes à un réseau ?
- ... ou protocole externe, global ?

Dans la même veine...

- Pouvez-vous trouver d'autres protocoles permettant des « fantaisies » similaires ?
- ... protocoles internes à un réseau ?
- DHCP, BootP
- ... ou protocole externe, global ?

Dans la même veine...

- Pouvez-vous trouver d'autres protocoles permettant des « fantaisies » similaires ?
- ... protocoles internes à un réseau ?
- DHCP, BootP
- ... ou protocole externe, global ?
- BGP (<https://www.kentik.com/blog/a-brief-history-of-the-internets-biggest-bgp-incidents/>)